VULNERABILITY ASSESSMENT REPORT

Target Application: Altoro Mutual(testfire.net)

Prepared By:Jebin A
Role: Cyber Security
Intern Organization: Future Interns
Date: April 2026

Introduction

This document outlines the results obtained from a security evaluation carried out on the Altoro Mutual application hosted at testfire.net. The review was conducted without prior knowledge of the system's internal configuration, relying solely on external observation and controlled interaction techniques to uncover potential weaknesses. The main objective of this analysis is to identify existing security gaps, describe their possible consequences in an easy-to-understand manner, and suggest actionable measures that can strengthen the application's defense against potential threats.

Objective

The purpose of this assessment is to examine the security condition of the selected web application and uncover any possible weaknesses that could be exploited. This process involves:

- Discovering accessible network services and entry points
- Evaluating the absence or insufficiency of security controls
- Reviewing system and application configurations for potential flaws

The overall aim is to present the findings in a well-organized manner, along with meaningful insights that support strengthening the application's security framework.

scope

- Target: http://testfire.net/
- Public-facing pages only
- No authentication or login bypass attempted
- Passive testing techniques only

Methodology

1. Reconnaissance using Nmap
2. Passive vulnerability scanning using OWASP ZAP
3. Security header and cookie analysis using browser DevTools
4. Documentation and risk classification

Network Scan Findings (Nmap)

FINDING	RISK LEVEL	DESCRIPTION	IMPACT	REMEDIATION
Open HTTP Port (80)	Medium	Port 80 (HTTP) is open and accessible	Data is transmitted without encryption	Enforce HTTPS and redirect HTTP traffic
Server Information Disclosure	Low	Server reveals "Apache-Coyote" details	Helps attackers identify vulnerabilities	Hide server version information

FIGURE 1: NMAP SCAN RESULTS SHOWING OPEN PORTS

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sV -Pn testfire.net
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-14 03:58 EDT
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.36s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE    VERSION
80/tcp   open   tcpwrapped
443/tcp  open   ssl/http   Apache Tomcat/Coyote JSP engine 1.1
8080/tcp open   http       Apache Tomcat/Coyote JSP engine 1.1
8443/tcp closed https-alt

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 48.32 seconds
```

FIGURE 2: RESULTS SHOWING SERVER INFORMATION EXPOSURE

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -A testfire.net
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-14 04:06 EDT
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.32s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE    VERSION
80/tcp   open   tcpwrapped
|_http-server-header: Apache-Coyote/1.1
|_http-title: Altoro Mutual
443/tcp  open   tcpwrapped
|_http-title: Altoro Mutual
|_ssl-date: 2026-04-14T08:08:13+00:00; +3s from scanner time.
| ssl-cert: Subject: commonName=demo.testfire.net
| Subject Alternative Name: DNS:demo.testfire.net
| Not valid before: 2025-05-21T00:00:00
|_Not valid after:  2026-06-21T23:59:59
8080/tcp open   tcpwrapped
|_http-server-header: Apache-Coyote/1.1
|_http-title: Altoro Mutual
8443/tcp closed https-alt
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2008|7|10 (88%), FreeBSD 6.X (86%)
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:freebsd:freebsd:6.2 cpe:/o:microsoft:windows_10
Aggressive OS guesses: Microsoft Windows 7 or Windows Server 2008 R2 (88%), FreeBSD 6.2-RELEASE (86%), Microsoft Windows Server 2008 R2 SP1 (86%), Microsoft Windows Server 2008 R2 (85%), Mi
crosoft Windows 10 1607 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 14 hops

Host script results:
|_clock-skew: 2s

TRACEROUTE (using port 8443/tcp)
HOP RTT       ADDRESS
1   3.94 ms   10.85.142.222
2   ...
3   35.49 ms  192.168.162.33
4   ...
5   35.51 ms  182.79.19.205
6   75.88 ms  116.119.161.109
7   ...
8   314.54 ms be41.br04.dal01.as3491.net (63.218.22.246)
9   ... 10
11  279.28 ms corec-dcpe4.dfw1.rackspace.net (148.62.41.103)
12  290.36 ms core9-corec.dfw1.rackspace.net (148.62.41.125)
13  281.71 ms core9-aggr171a-8.dfw3.rackspace.net (74.205.108.61)
14  276.78 ms 65.61.137.117

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 101.99 seconds
```

Vulnerability Findings (OWASP ZAP)

VULNERABILITY	RISK LEVEL	DESCRIPTION	IMPACT	REMEDIATION
Absence of Anti-CSRF Tokens	Medium	Application does not include CSRF protection	Attackers can perform actions on behalf of users	Implement anti-CSRF tokens in forms
Missing Content Security Policy (CSP)	Medium	CSP header is not set	Increased risk of XSS attacks	Add Content-Security-Policy header
Missing Anti-clickjacking Header	Low	X-Frame-Options header is missing	Application may be vulnerable to clickjacking	Add X-Frame-Options header
X-Content-Type-Options Header Missing	Low	Browser MIME type protection not enabled	May allow content-type attacks	Set X-Content-Type-Options to "nosniff"

Figure 1: Absence of Anti-CSRF Tokens

History | Search | Alerts | Output | Spider | AJAX Spider | Active Scan

Alerts (15)
- Cross Site Scripting (Reflected) (2)
- SQL Injection (5)
- SQL Injection - SQLite (Time Based) (3)
- Absence of Anti-CSRF Tokens (3)
- Content Security Policy (CSP) Header Not Set (164)
- Missing Anti-clickjacking Header (62)
- Cookie without SameSite Attribute (3)
- Cross-Domain JavaScript Source File Inclusion
- Server Leaks Version Information via "Server" HTTP Response Header Field (206)
- X-Content-Type-Options Header Missing (101)
- ZAP is Out of Date
- Information Disclosure - Suspicious Comments (10)
- Modern Web Application (6)
- Session Management Response Identified (3)
- User Agent Fuzzer (108)

Absence of Anti-CSRF Tokens

URL: http://testfire.net/login.jsp
Risk: Medium
Confidence: Low
Parameter:
Attack:
Evidence: <form action="doLogin" method="post" name="login" id="login" onsubmit="return (confirminput(login));">
CWE ID: 352
WASC ID: 9
Source: Passive (10202 - Absence of Anti-CSRF Tokens)
Input Vector:

Description:

No Anti-CSRF tokens were found in a HTML submission form.
A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the

Other Info:

No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, csrfToken] was found in the following HTML form: [Form 2: "btnSubmit" "passw" "uid"

Figure 2: Missing Content Security Policy (CSP)

Alerts (15)
- Cross Site Scripting (Reflected) (2)
- SQL Injection (5)
- SQL Injection - SQLite (Time Based) (3)
- Absence of Anti-CSRF Tokens (3)
- Content Security Policy (CSP) Header Not Set (164)
- Missing Anti-clickjacking Header (62)
- Cookie without SameSite Attribute (3)
- Cross-Domain JavaScript Source File Inclusion
- Server Leaks Version Information via "Server" HTTP Response Header Field (206)
- X-Content-Type-Options Header Missing (101)
- ZAP is Out of Date
- Information Disclosure - Suspicious Comments (10)
- Modern Web Application (6)
- Session Management Response Identified (3)
- User Agent Fuzzer (108)

Content Security Policy (CSP) Header Not Set

URL: http://testfire.net
Risk: Medium
Confidence: High
Parameter:
Attack:
Evidence:
CWE ID: 693
WASC ID: 15
Source: Passive (10038 - Content Security Policy (CSP) Header Not Set)
Alert Reference: 10038-1
Input Vector:

Description:

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are

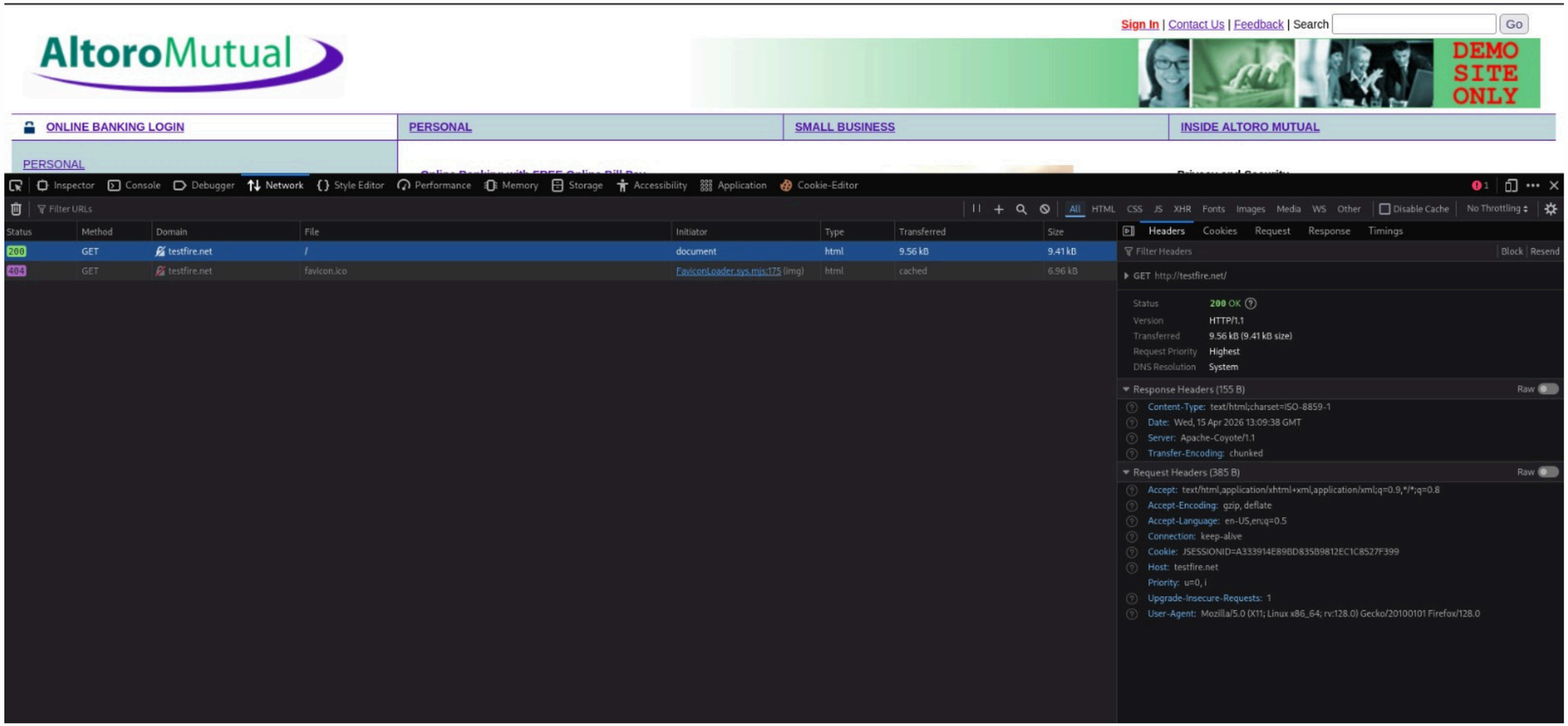
Other Info:

Figure 3: Missing Anti-clickjacking Header

Security Configuration Analysis (Browser DevTools)

FINDING	RISK LEVEL	DESCRIPTION	IMPACT	REMEDIATION
Missing Security Headers	Medium	Important headers like CSP and X-Frame-Options are not implemented	Increased risk of XSS and clickjacking attacks	Add CSP, X-Frame-Options, and X-Content-Type-Options headers
Insecure Cookie Configuration	Medium	Cookies lack Secure, HttpOnly, and SameSite attributes	Session hijacking and data exposure risks	Enable Secure, HttpOnly, and SameSite flags

Figure 1 : Browser DevTools showing response headers and cookie configuration



Risk Summary

Vulnerability	Risk Level
Open HTTP Port	Medium
Server Information Disclosure	Low
Missing Content Security Policy	Medium
Absence of Anti-CSRF Tokens	Medium
Missing Anti-clickjacking Header	Low
Insecure Cookie Configuration	Medium

Conclusion

The vulnerability assessment identified several security weaknesses related to missing protections and configuration issues.

While no critical vulnerabilities were exploited, these issues may increase the risk of attacks if left unaddressed.

By implementing the recommended security measures, the overall security posture of the application can be significantly improved.

Recommendations

- Enforce HTTPS across the entire application
- Implement essential security headers
- Secure cookies using proper attributes
- Hide server information from responses
- Perform regular vulnerability assessments
- Follow secure coding practices